REPORT DI SICUREZZA & ANALISI VULNERABILITÀ PHISHING

Caso Studio: Tentativo di Social Engineering e Risarcimento Danni via QR Code

1. SINTESI DEL MESSAGGIO FRAUDOLENTO RICEVUTO

Email di Phishing ad Alto Impatto Emotivo

L'email ricevuta da **Chandra Richter** (ricercatrice responsabile dei brevetti) simula una comunicazione formale ed estremamente urgente da parte di **Nicolas Tordjman** (Area Marketing & Direzione). Nel testo viene contestata una presunta compromissione del brevetto del nuovo prodotto, accusandola di violazione degli accordi di riservatezza con un danno stimato in milioni di euro e richiedendo un pagamento sanzionatorio immediato di **5.000.000 €** tramite scansione di un **QR Code**.

Mittente Falso	`nicolas_tordjman.cotyinc@sponserme.store`
Destinatario	`c.richter@eatsnackish.com`
Oggetto	`URGENTE: Compromissione brevetto e avvio procedura di risarcimento danni`
Vettore d'Attacco	`QR Code per saldo sanzione immediato (Quishing)`

2. VULNERABILITÀ EMOTIVA E RUOLO AZIENDALE DI NICOLAS

Impatto Emotivo e Stato di Shock

Una comunicazione di questa gravità, che addebita una responsabilità economica devastante (5 milioni di euro) e minaccia azioni legali immediate, genera un forte stato di agitazione e stress psicologico. Trovandosi scossa e sotto pressione, Chandra potrebbe non prestare attenzione ai dettagli tecnici dell'intestazione — come il dominio anomalo dell'email (`@sponserme.store` anziché i canali ufficiali Coty / Kylie) — e procedere impulsivamente alla scansione del QR Code nel tentativo di risolvere la situazione.

Verosimiglianza del Mittente

Anche se Chandra e Nicolas non lavorano a stretto contatto quotidiano, la ricezione di un'email da parte di Nicolas è ritenuta assolutamente plausibile e credibile. Dato il suo ruolo di **General Manager / Responsabile dell'Area Marketing & Governance** nell'organizzazione Kylie, è perfettamente coerente che un problema strategico o legale di portata globale sul brevetto venga gestito direttamente dai vertici aziendali.

3. LINEE GUIDA DI SICUREZZA E VERIFICHE PREVENTIVE

Azioni Obbligatorie Prima di Inquadrare qualsiasi QR Code

Prima di effettuare qualsiasi azione, accedere a link o inquadrare QR code presenti in comunicazioni d'emergenza, Chandra (e qualsiasi membro del team) deve applicare le seguenti verifiche:

1. **Contatto Diretto via Canali Interni/Privati:** Contattare direttamente il referente interessato (Nicolas Tordjman o il team legale) tramite numero di telefono privato, estensione aziendale nota o chat interna verificata per confermare l'effettivo invio del messaggio.
2. **Verifica delle Fonti Pubbliche e Ricerca Online:** Effettuare una semplice e rapida ricerca sul web. Se la tecnologia di un prodotto appena lanciato sul mercato (come *k2o*) fosse stata realmente compromessa da un concorrente, l'argomento sarebbe già oggetto di forte dibattito pubblico, articoli di testate giornalistiche di settore e comunicati stampa ufficiali.
3. **Analisi Tecnica dell'Intestazione (Header):** Verificare sempre che il dominio di provenienza corrisponda esattamente a quello ufficiale dell'azienda e mai a domini generici o temporanei (es. `tempmail` o `sponserme.store`).